

ДОМАШНЄ ЗАВДАННЯ 4

Asset Management and Data Security

Розробка політики керування даними на основі попередніх результатів

Політика доступу, обміну, зберігання, знищення даних
та визначення власників даних

ПІБ	Ігор Задорожняк
Обрана організація	Умовна банківська організація
Основний ризик	Витік конфіденційних даних клієнтів банку
Формат документа	Політика керування даними

Короткий опис документа

Документ описує правила доступу, обміну, зберігання та знищення даних у банківській організації. Також визначено власників даних і їхні обов'язки щодо конфіденційності, цілісності та доступності інформації.

Зміст документа

- 1. Мета документа
- 2. Використання попередніх результатів
- 3. Методологічна основа політики
- 4. Політика доступу до даних
- 5. Політика обміну даними
- 6. Політика зберігання даних
- 7. Політика знищення даних
- 8. Ідентифікація власників даних
- 9. Обов'язки власників даних щодо CIA
- 10. Додаткові організаційні правила
- 11. Відповідальність за порушення політики
- 12. Перегляд і оновлення політики
- 13. Чек-лист відповідності критеріям
- 14. Висновок
- 15. Короткий коментар для LMS
- 16. Використані джерела та стандарти

Примітка

Зміст подано як структурний перелік розділів. Після завантаження у Google Docs за потреби можна автоматично додати зміст через меню: Insert → Table of contents.

1. Мета документа

Метою цього документа є розробка політики керування даними для банківської організації на основі попередньо визначених активів, категорій даних та результатів аналізу ризиків.

Політика визначає правила доступу, обміну, зберігання та знищення даних. Також у документі визначено власників даних, їхні обов'язки щодо забезпечення конфіденційності, цілісності та доступності інформації.

Ця політика спрямована на зменшення ризику витоку конфіденційної інформації, несанкціонованого доступу, втрати даних, пошкодження інформаційних активів та порушення вимог безпеки.

2. Використання попередніх результатів

У попередніх завданнях було обрано банківську організацію, для якої основним ризиком визначено витік конфіденційних даних клієнтів. У попередньому аналізі ризиків було встановлено, що цей ризик є високим, оскільки потенційна частота атак і можливі фінансові втрати є суттєвими.

Для зменшення ризику було визначено такі базові заходи контролю: багатофакторна автентифікація, навчання персоналу щодо фішингу, SIEM і моніторинг логів, фізичний контроль доступу, резервне копіювання та Disaster Recovery.

2.1. Основні категорії даних

Категорія даних	Приклади даних	Основні активи	Рівень чутливості
Клієнтські дані	ПІБ клієнтів, адреси, телефони, email, паспортні дані, ідентифікаційні номери	CRM-система, база клієнтів, банківські застосунки	Високий
Фінансові дані	Баланси рахунків, транзакції, кредити, платежі, фінансова звітність	Core banking system, бухгалтерська система, платіжні шлюзи	Критичний
Платіжні дані	Дані карток, реквізити платежів, історія операцій	Платіжна система, процесингові сервіси	Критичний
Внутрішні корпоративні дані	Внутрішні документи, політики, процедури, службове листування	Google Workspace / Microsoft 365, внутрішній файловий сервер	Середній / високий
Дані працівників	Особові справи, зарплата, контакти, документи HR	HR-система, бухгалтерія	Високий
Технічні та security-дані	Логи, SIEM-події, облікові записи, конфігурації серверів, резервні копії	SIEM, сервери, мережеве обладнання, backup-сховище	Високий / критичний
Публічні дані	Інформація на сайті, рекламні матеріали, публічні контакти	Вебсайт, соціальні мережі	Низький

3. Методологічна основа політики

Політика враховує загальноприйняті підходи до кібербезпеки та керування інформаційними активами. Для структурування правил використано принципи керування ризиками, захисту інформаційних активів, мінімальних привілеїв, журналювання, шифрування, контролю доступу та безпечного знищення даних.

Як орієнтири для політики можуть використовуватися NIST Cybersecurity Framework, ISO/IEC 27001, ISO/IEC 27002, NIST SP 800-88 та принципи захисту персональних даних, зокрема мінімізація даних, обмеження строку зберігання, конфіденційність, цілісність і підзвітність.

Ключова ідея

Політика керування даними повинна відповідати реальним активам організації: де дані зберігаються, хто ними користується, як вони передаються, як довго зберігаються і як видаляються.

4. Політика доступу до даних**4.1. Загальні принципи доступу**

Доступ до даних банку надається лише відповідно до службових обов'язків працівника. Основним принципом є принцип мінімальних привілеїв: кожен працівник отримує тільки той рівень доступу, який потрібен для виконання його роботи.

Доступ до конфіденційних і критичних даних не може надаватися автоматично або без погодження відповідального власника даних. Усі запити на доступ мають бути задокументовані, погоджені керівником підрозділу та перевірені IT/Security-відділом.

4.2. Рівні доступу за ролями

Роль	Дозволений доступ	Обмеження
Керівництво банку	Аналітичні звіти, фінансові показники, агреговані клієнтські дані	Не повинно мати прямого доступу до технічних облікових записів або сирих баз даних без потреби
Фінансовий відділ	Фінансові операції, звітність, бухгалтерські документи	Доступ лише до фінансових даних у межах службових задач
Клієнтський відділ	Дані клієнтів, необхідні для обслуговування	Заборонено масове вивантаження клієнтської бази без погодження
IT-відділ	Сервери, системи, резервні копії, технічні журнали	Не повинен переглядати зміст клієнтських і фінансових даних без офіційної потреби
Security/SOC	SIEM, логи, інциденти, події безпеки	Доступ використовується лише для моніторингу, розслідувань і реагування
HR-відділ	Дані працівників	Немає доступу до клієнтських і платіжних даних
Аудит / Compliance	Дані для перевірок, політики, журнали доступу	Доступ тимчасовий, контрольований і логований
Зовнішні підрядники	Лише мінімальний технічний доступ за договором	Доступ обмежений у часі, під NDA, з MFA та журналюванням

4.3. Вимоги до автентифікації

Для всіх працівників банку обов'язково використовується багатофакторна автентифікація. Особливо це стосується доступу до внутрішніх систем, адміністративних панелей, VPN, хмарних сервісів, SIEM, backup-систем і фінансових застосунків.

- мінімальна довжина пароля — не менше 12 символів;
- заборона повторного використання старих паролів;
- заборона використання простих або скомпрометованих паролів;
- використання менеджера паролів для службових акаунтів;
- окремі адміністративні облікові записи для privileged access;
- негайне блокування акаунтів звільнених працівників;
- перегляд доступів не рідше одного разу на квартал.

Для адміністраторів має використовуватися окремий privileged account. Адміністративний доступ повинен бути тимчасовим, журналюватися та надаватися тільки за потреби.

5. Політика обміну даними

5.1. Внутрішній обмін даними

Обмін даними всередині організації дозволяється тільки через затверджені корпоративні канали: корпоративну пошту, захищені файлові сховища, внутрішні системи документообігу або контрольовані хмарні середовища.

Заборонено передавати клієнтські, фінансові, платіжні або security-дані через особисту пошту, особисті месенджери, незахищені USB-носії або відкриті файлові сервіси.

- шифрування файлів під час передачі;
- контроль доступу до папок і документів;
- обмеження права завантаження або копіювання;
- використання DLP для запобігання несанкціонованому витоку;
- журналювання доступу до важливих файлів;
- передача лише мінімально необхідного обсягу даних.

5.2. Зовнішній обмін даними

Передача конфіденційних даних зовнішнім сторонам допускається тільки за наявності законної або договірної підстави. Передача повинна бути погоджена власником даних, Compliance-відділом і, за потреби, юридичним відділом.

- наявність договору або NDA;
- визначення мети передачі;
- мінімізація обсягу переданих даних;
- використання шифрування;
- перевірка отримувача;
- журналювання факту передачі;
- заборона подальшого передавання даних без дозволу банку.

Платіжні, клієнтські та персональні дані повинні передаватися лише через захищені канали, наприклад VPN, TLS-з'єднання, захищені API або контрольовані платформи обміну.

6. Політика зберігання даних

6.1. Загальні вимоги до зберігання

Дані банку повинні зберігатися у затверджених середовищах: на серверах організації, у захищених базах даних, у контрольованих хмарних сервісах або в резервних сховищах. Місце зберігання залежить від категорії та рівня чутливості даних.

Заборонено зберігати конфіденційні дані на особистих пристроях працівників, незашифрованих USB-носіях, особистих хмарних акаунтах або локальних комп'ютерах без погодження IT/Security-відділу.

6.2. Зберігання за категоріями даних

Категорія даних	Місце зберігання	Основні вимоги
Клієнтські дані	Захищена CRM / база даних банку	Шифрування, MFA, RBAC, журналювання доступу
Фінансові дані	Core banking system, бухгалтерська система	Шифрування, контроль цілісності, backup, аудит
Платіжні дані	Платіжна інфраструктура / процесинг	Посилений контроль доступу, сегментація, моніторинг
Дані працівників	HR-система	Обмежений доступ HR і керівництва
Технічні логи	SIEM / централізоване сховище логів	Захист від зміни, контроль retention, моніторинг
Резервні копії	Backup-сховище, бажано immutable	Шифрування, тестування відновлення,

Категорія даних	Місце зберігання	Основні вимоги
	backup	обмежений доступ
Публічні дані	Вебсайт, публічні ресурси	Перевірка перед публікацією, контроль змін

6.3. Резервне копіювання та доступність

Для критичних систем банку повинно виконуватися регулярне резервне копіювання. До критичних систем належать клієнтська база, фінансові системи, платіжна інфраструктура, SIEM, конфігурації серверів і важливі внутрішні документи.

- резервні копії створюються за затвердженим графіком;
- копії зберігаються окремо від основної інфраструктури;
- backup повинен бути зашифрованим;
- доступ до backup-сховищ має бути обмежений;
- відновлення даних регулярно тестується;
- критичні копії захищаються від ransomware за допомогою immutable backup або offline-копій.

Показник	Рекомендоване значення	Пояснення
RPO	Не більше 4 годин для критичних фінансових і клієнтських даних	Максимальний допустимий обсяг втрати даних у часі
RTO	Не більше 8 годин для ключових сервісів	Максимальний допустимий час відновлення сервісу
Менш критичні дані	RPO/RTO можуть бути довшими	Визначаються залежно від бізнес-потреб

7. Політика знищення даних

7.1. Загальні принципи знищення

Дані повинні знищуватися лише після завершення строку їх законного, договірної або операційного зберігання. Перед знищенням власник даних повинен підтвердити, що дані більше не потрібні для бізнес-процесів, аудиту, юридичних вимог або розслідувань інцидентів.

Знищення даних повинно бути контрольованим, задокументованим і перевіреном. Для критичних і конфіденційних даних необхідно зберігати запис про знищення: які дані були знищені, хто погодив знищення, хто виконав процедуру, коли це було зроблено і яким методом.

7.2. Методи знищення

Тип носія / даних	Метод знищення
Паперові документи	Подрібнення у шредері або передача сертифікованому постачальнику з актом знищення
HDD-диски	Перезапис, криптографічне стирання або фізичне знищення
SSD-диски	Secure erase, cryptographic erase або фізичне знищення
USB-носії	Повне стирання або фізичне знищення
Хмарні дані	Видалення через затверджені процедури провайдера, перевірка retention і backup-копій
Резервні копії	Видалення після завершення строку зберігання згідно з backup retention policy

Тип носія / даних	Метод знищення
Облікові записи	Деактивація, видалення доступів, архівація журналів активності

Важливо

Просте видалення файлів не вважається достатнім методом знищення для конфіденційних або критичних даних. Для таких даних потрібно застосовувати безпечне стирання, криптографічне стирання або фізичне знищення носія.

8. Ідентифікація власників даних

Власник даних — це відповідальна особа або підрозділ, який визначає правила використання певної категорії даних, погоджує доступ, контролює якість даних і відповідає за їх захист.

Категорія даних	Власник даних	Основні обов'язки
Клієнтські дані	Керівник клієнтського напрямку / Data Protection Officer	Контроль доступу до клієнтських даних, захист персональної інформації, погодження передачі третім сторонам
Фінансові дані	CFO / фінансовий директор	Забезпечення точності фінансових записів, контроль доступу фінансового відділу, відповідність вимогам аудиту
Платіжні дані	Керівник платіжних операцій	Захист платіжних операцій, контроль процесингових систем, мінімізація доступу
Дані працівників	HR-директор	Конфіденційність HR-даних, контроль доступу до особових справ, дотримання строків зберігання
Технічні дані та логи	IT-директор / CISO	Захист серверів, логів, SIEM, backup, контроль адміністраторів
Security-інциденти	CISO / SOC Lead	Моніторинг інцидентів, реагування, збереження доказів, підготовка звітів
Публічні дані	Marketing / PR-відділ	Перевірка інформації перед публікацією, запобігання розміщенню конфіденційних даних

9. Обов'язки власників даних щодо СІА

9.1. Конфіденційність

Власники даних повинні забезпечити, щоб доступ до інформації мали лише авторизовані особи. Для цього вони погоджують права доступу, контролюють використання даних, ініціюють перегляд доступів і повідомляють Security-відділ про підозрілі дії.

Приклад: власник клієнтських даних повинен переконатися, що працівник клієнтського відділу бачить лише ті дані, які потрібні для обслуговування клієнта, але не має можливості масово експортувати всю клієнтську базу.

9.2. Цілісність

Власники даних відповідають за точність, актуальність і повноту даних. Вони повинні контролювати, щоб дані не були змінені без дозволу, випадково пошкоджені або підмінені.

- контроль змін;
- журналювання операцій;
- розмежування прав на читання і редагування;
- перевірка правильності даних;

- регулярний аудит;
- резервне копіювання.

Приклад: фінансовий директор відповідає за те, щоб фінансові звіти були точними, а зміни у фінансових записях могли виконувати лише уповноважені працівники.

9.3. Доступність

Власники даних разом з IT-відділом повинні забезпечити, щоб критичні дані були доступні тоді, коли вони потрібні для роботи банку. Для цього використовуються backup, Disaster Recovery, моніторинг систем, резервні канали зв'язку та плани відновлення.

Приклад: якщо основна база клієнтів стає недоступною через технічний збій або кібератаку, банк повинен мати можливість відновити її з резервної копії у визначений час.

10. Додаткові організаційні правила

10.1. Перегляд доступів

Усі права доступу до критичних систем повинні переглядатися не рідше одного разу на квартал. Після звільнення працівника або зміни його посади доступи повинні бути змінені або заблоковані негайно.

10.2. Моніторинг і журналювання

Доступ до клієнтських, фінансових, платіжних і технічних даних повинен журналюватися. Логи повинні передаватися до SIEM для виявлення підозрілих дій, наприклад масового експорту даних, входу з незвичної локації, невдалих спроб входу або використання привілейованих акаунтів.

10.3. Навчання персоналу

Працівники банку повинні регулярно проходити навчання з інформаційної безпеки. Особлива увага приділяється phishing-атакам, правилам роботи з конфіденційними даними, безпечному обміну файлами, використанню MFA та повідомленню про інциденти.

10.4. Реагування на інциденти

У разі підозри на витік даних працівник повинен негайно повідомити IT/Security-відділ або CISO. Заборонено самостійно видаляти підозрілі файли, змінювати журнали подій або приховувати факт інциденту.

- зафіксувати інцидент;
- визначити обсяг потенційного витоку;
- ізолювати уражені системи;
- зберегти докази;
- повідомити керівництво;
- за потреби залучити юридичний і compliance-відділ;
- підготувати план відновлення.

11. Відповідальність за порушення політики

Порушення цієї політики може призвести до дисциплінарних заходів, обмеження доступу, службового розслідування або юридичних наслідків.

- передача конфіденційних даних через незахищені канали;
- використання особистої пошти для службових даних;
- копіювання клієнтської бази без дозволу;
- передача паролів іншим особам;
- обхід MFA;
- несанкціоноване видалення або зміна даних;
- приховування інциденту безпеки.

12. Перегляд і оновлення політики

Ця політика повинна переглядатися не рідше одного разу на рік або після суттєвих змін у системах банку, появи нових ризиків, інцидентів безпеки, результатів аудиту або змін у законодавчих вимогах.

Відповідальним за перегляд політики є CISO разом з IT-директором, Compliance-відділом, юридичним відділом і власниками основних категорій даних.

13. Чек-лист відповідності критеріям

Критерій прийняття	Як виконано у документі	Статус
Політика описує правила доступу до даних	Розділ 4 містить принципи доступу, ролі, MFA та парольну політику	Виконано
Політика описує правила обміну даними	Розділ 5 описує внутрішній і зовнішній обмін, шифрування, VPN, NDA та контроль передачі	Виконано
Політика описує правила зберігання даних	Розділ 6 визначає місця зберігання, backup, RPO/RTO і захист резервних копій	Виконано
Політика описує правила знищення даних	Розділ 7 визначає методи знищення фізичних і цифрових носіїв	Виконано
Визначено власників даних	Розділ 8 визначає відповідальних осіб для кожної категорії даних	Виконано
Описано обов'язки власників даних	Розділ 9 пояснює обов'язки щодо конфіденційності, цілісності та доступності	Виконано
Документ має чітку структуру	Документ містить титульну сторінку, зміст, розділи, таблиці та висновок	Виконано

14. Висновок

Розроблена політика керування даними визначає основні правила доступу, обміну, зберігання та знищення даних у банківській організації. Вона враховує попередньо визначений ризик витоку конфіденційних даних клієнтів і базується на принципах мінімальних привілеїв, багатофакторної автентифікації, шифрування, журналювання, резервного копіювання та контрольованого знищення інформації.

У документі також визначено власників даних для кожної категорії та описано їхні обов'язки щодо конфіденційності, цілісності та доступності. Такий підхід допомагає організації зменшити ризик витоку інформації, підвищити контроль над інформаційними активами та забезпечити більш системне управління даними.